

User Awareness & Training Package

DLP training program guide with session outlines, presentation scripts, quizzes and certificate template

Document ID	TRN-DLP-001
Version	1.0 (template)
Classification	Internal
Owner	[Data Protection Officer / IT Security Manager]
Approved by	[Name, Title]
Effective date	[DD Month YYYY]
Next review	[DD Month YYYY — review at least annually]

Customization required

This template is a starting point published by the OpenDLP-LK community. Replace all bracketed placeholders, adapt the content to your organization's size, industry and risk profile, and obtain legal review before adoption. Aligned with Sri Lanka's Personal Data Protection Act (PDPA) No. 9 of 2022.

<https://opendlp-lk.github.io> • Licensed under MIT — free to use, adapt and redistribute.

1. Program Overview

This package equips [Organization Name] to run a complete DLP awareness program: onboarding for new staff, annual refreshers, role-specific modules and incident response drills. Adapt timings and examples to your organization; localized Sri Lankan examples (NIC numbers, PDPA obligations) are included throughout.

Component	Audience	Duration	Frequency
New employee onboarding	All new hires	60 min	Within first week
Annual refresher	All staff	45 min	Yearly
Role-specific modules	Developers, HR, Finance, Executives, IT	30–60 min	Yearly
Incident response tabletop	IRT + managers	90 min	Twice yearly
Phishing simulation	All staff	Continuous	Quarterly campaigns

2. Module 1 — New Employee Onboarding (60 min)

Session outline

Time	Topic	Key points
0–10 min	Why data protection matters	PDPA No. 9 of 2022 basics; real Sri Lankan breach examples; personal accountability.
10–25 min	Data classification	Four levels; how to label documents and email; NIC/passport/financial data are always RESTRICTED.
25–40 min	Acceptable use essentials	Approved channels; USB and cloud rules; password + MFA; screen locking.
40–50 min	Recognizing and reporting incidents	What an incident looks like; no-blame reporting; security contact details.
50–60 min	Quiz and acknowledgment	Quiz A (below); sign AUP acknowledgment form.

Presenter script highlights

Opening: “Every one of you will handle personal data of Sri Lankan citizens — customer NIC numbers, phone numbers, salaries. Under the PDPA, mishandling that data has real legal consequences for the company, and losing it has real consequences for real people. This hour shows you the small set of habits that prevent almost all data loss incidents.”

Classification demo: show the same spreadsheet three ways — unlabeled, labeled CONFIDENTIAL, and with an NIC column added — and ask the room to classify each. Emphasize: one NIC column makes the whole file RESTRICTED.

Reporting close: “If you ever send something to the wrong person — tell us within the hour. A mistake reported in an hour is a contained incident; a mistake hidden for a week is a breach notification to the regulator.”

3. Module 2 — Annual Refresher (45 min)

- Policy updates and changes since last year (10 min) — present a one-slide diff of what changed.
- Recent incident case studies (15 min) — anonymized internal near-misses plus one public Sri Lankan or regional breach; walk the timeline and the control that failed.
- Emerging threats (10 min) — current phishing lures, QR-code phishing, AI-generated impersonation, cloud sharing mistakes.
- Best practices reinforcement (5 min) — the five habits: label, lock, verify recipient, approved channels, report fast.
- Quiz B and compliance certification (5 min).

4. Module 3 — Role-Specific Modules (30–60 min each)

Role	Focus areas
Developers	Secure handling of production data; no real personal data in dev/test; secrets management; masking NIC/card numbers in logs; code repository hygiene.
HR	Personnel files and special-category data; recruitment data retention; sharing employee data with third parties (EPF/ETF, banks, insurers) securely.
Finance	Bank account and card data handling; payment fraud and BEC scams; supplier data verification; reconciliation report distribution.
Executives	Strategic data in email and travel scenarios; whaling/BEC targeting; board pack handling; approving data sharing agreements.
IT administrators	DLP console operation; alert triage workflow; least-privilege administration; evidence preservation during incidents.

5. Module 4 — Incident Response Tabletop (90 min)

Scenario: an employee reports that a spreadsheet containing 8,000 customer records (names, NIC numbers, phone numbers) was attached to an email sent to an external supplier by mistake three days ago.

- Inject 1 (0 min): initial report arrives. Team must classify severity and open an incident record.
- Inject 2 (20 min): supplier confirms the file was forwarded internally on their side. Discuss containment options and evidence.
- Inject 3 (40 min): DPO must decide — is this notifiable to the Data Protection Authority under PDPA Section 23? Draft the notification skeleton.
- Inject 4 (60 min): a journalist calls. Communications lead responds using the holding statement template.
- Debrief (75–90 min): timeline review, gaps found, corrective actions with owners.

6. Quiz A — Onboarding (answer key at end)

1. A file contains customer names and NIC numbers. What classification applies? (a) Internal (b) Confidential (c) Restricted (d) Public

2. You need to send a salary file to the company's bank. Which channel do you use? (a) Personal Gmail (b) WhatsApp (c) Approved secure transfer service (d) USB drive
3. You accidentally emailed a client list to the wrong recipient. What do you do first? (a) Delete the sent mail and hope (b) Report to security immediately (c) Ask the recipient to delete it and tell no one (d) Wait to see if anyone notices
4. Which is an acceptable password practice? (a) Reusing your banking password (b) Sharing with your manager (c) Unique password + MFA (d) Writing it on a sticky note
5. Under the PDPA, a notifiable personal data breach must be reported to the Data Protection Authority — who makes this call in our organization? (a) Any employee (b) The DPO (c) The intern (d) Nobody

Quiz B — Annual refresher

1. Name the four classification levels in order of sensitivity.
2. Give two examples of data that is always RESTRICTED in Sri Lanka.
3. What is the maximum time you should wait before reporting a suspected incident?
4. True/False: auto-forwarding corporate email to a personal mailbox is allowed if convenient.
5. What does the DLP system do when you attempt to email a file containing NIC numbers externally?

Answer key — Quiz A: 1(c), 2(c), 3(b), 4(c), 5(b). Quiz B: 1: Restricted, Confidential, Internal, Public; 2: e.g. NIC numbers, health records, card numbers; 3: immediately — within the hour; 4: False; 5: [per your configuration — e.g. blocks and alerts security].

Passing score: [80%]. Record results in the training register; re-test after remediation for scores below threshold.

7. Video Script — 2-minute awareness short: “The Wrong Attachment”

SCENE 1 (0:00–0:20) — Open on Sanduni, finance officer, drafting an email at 4:55 pm. Voice-over: “It’s Friday. One last email.” She types a supplier’s name; autocomplete fills a similar external address. SCENE 2 (0:20–0:50) — She attaches “payroll_march.xlsx” and hovers over Send. Freeze frame. VO: “This file has 214 employees’ NIC numbers and salaries. Watch what the next click decides.” SCENE 3 (0:50–1:20) — Path A: she sends; Monday, the DPO is drafting a regulator notification. Path B: a DLP prompt appears — ‘This file contains NIC numbers. Confirm recipient?’ She spots the wrong address and fixes it. SCENE 4 (1:20–2:00) — VO over checklist graphic: “Verify the recipient. Heed the warning. Report mistakes fast. Data protection is a five-second habit.” End card: security contact details.

8. Certificate of Completion (template)

Certificate of Completion

This certifies that

[Employee Name]

has successfully completed the

[Module name] — Data Loss Prevention & PDPA Awareness Training

conducted by [Organization Name] on [date], with a score of [XX%].

Trainer signature

DPO / HR signature

Training register

Track for each employee: modules completed, dates, quiz scores, certificate issued (Y/N), next due date. Retain records for [3] years for audit and PDPA accountability evidence.